Milestone 4 - Closeout
Open-Source Vulnerability Scanner for Cardano Smart Contracts

UnboundedMarket Team

February 4, 2026

Contents

1 Motivation

Smart contract vulnerabilities present a serious risk to Blockchain ecosystems, such as Cardano, and can lead to significant financial losses, undermining trust in the platform. Existing auditing processes mitigate this risk but are time-consuming and costly and may overlook critical bugs, which can hinder Cardano's adoption and growth. Recent studies have demonstrated the potential of large language models (LLMs) to identify coding errors and vulnerabilities in smart contract languages such as Solidity, which are used on Ethereum. Building on these findings, we aim to bring these capabilities to the Cardano ecosystems by fine-tuning a large language model to identify bugs in Cardano smart contracts.

While our tool is not intended to be a standalone solution for ensuring bug-free smart contracts, it provides an additional layer of security by finding potential bugs and vulnerabilities early in the development process. Smart contract audits typically involve multiple iterations; after identifying and addressing a bug or vulnerability, an additional audit is required to confirm the fix. By enabling early vulnerability detection, we hope that our tool reduces the number of audit iterations, reducing the overall cost and time of the process. Furthermore, it may identify subtle bugs that could be overlooked in manual audits. We thus hope that our tool will improve the accuracy and efficiency of smart contract audits, reducing vulnerabilities and increasing the security of smart contracts within the Cardano ecosystem.

This report represents the completion of the fourth and final milestone of our Project Catalyst Fund 12 project, *Open-Source Vulnerability Scanner for Cardano Smart Contracts*.

2 Project Overview (Name, Link, ID, Dates)

All relevant project details, including the name, link, number, manager, and start & completion dates, are given in table 1.

Item	**Details**
Project Name	Open-Source Vulnerability Scanner for Cardano Smart Contracts
Project Catalyst URL	https://projectcatalyst.io/funds/12/cardano-open-developers/open-source-vulnerability-scanner-for-cardano-smart-contracts
Project Number	1200174
Project Manager	UnboundedMarket
Project Dates	Start: Aug 12, 2024 — Completion: Jan 23, 2026

Table 1: Project overview

3 Project Outcomes and Impact

3.1 Key Deliverables

This project delivers three major contributions to the Cardano ecosystem:

1. **Comprehensive vulnerability dataset:** A curated dataset of 947 Cardano smart contracts with systematically introduced vulnerabilities, covering Plutus, Aiken, and OpShin. The dataset is extensible and sourced from 40 public repositories.

2. **Complete ML pipeline:** A fully documented pipeline for data collection, preprocessing, augmentation, training, and evaluation. All scripts are open-source and adaptable for other security analysis tasks.

3. **Production-ready vulnerability scanner:** A fine-tuned OpenLLaMA-3B model achieving 94.8% accuracy (up from 92.8% baseline), with perplexity reduced from 63.3 to 7.9. The model is publicly available on HuggingFace with user-friendly scripts and comprehensive documentation.

All contributions are open-source under the MIT License, enabling the Cardano community to build upon this foundation.

3.2 Design Philosophy

Intentional bias toward detection: Our model is fine-tuned on a dataset with class imbalance, causing it to overpredict bugs intentionally. This design serves developers by flagging potential vulnerabilities with explanations, which developers then review to confirm. We prioritize catching potential issues over minimizing false positives, as missing a vulnerability is far more costly than reviewing clean code.

Community-centric: All data, code, and models are designed for reusability and extension by community members, with clear documentation and open licensing.

3.3 Key Learnings

- **Data quality is paramount:** Systematic vulnerability introduction and rigorous quality control were essential for effective model training.

- **Language-specific adaptation required:** Cardano's unique smart contract languages (especially Haskell-based Plutus) required specialized training data beyond Solidity-focused approaches.

- **Human-in-the-loop essential:** LLMs augment but do not replace human auditors. Our tool flags potential issues for expert review rather than serving as a final arbiter.

4 Milestone Summaries

4.1 First Milestone

The first milestone established the conceptual foundation of the project through comprehensive research and planning. The research report covered several key sections: a motivation section explaining the need for automated vulnerability detection in Cardano smart contracts, followed by extensive literature and market review examining recent advances in LLM-based bug detection and existing AI-assisted auditing tools.

The main section detailed all individual steps for developing the open-source vulnerability scanner, including data collection methodology, preprocessing strategies, and model fine-tuning approaches. We outlined two distinct fine-tuning methods: (1) a sequence-to-sequence approach and (2) a combined classification and generation method. The report also included a comprehensive project plan with timelines, resource allocation, and deliverables for all four milestones. A final section addressed the scope and limitations of the proposed tool, emphasizing its role in augmenting rather than replacing human auditors.

The complete research report is publicly available and served as the blueprint for all subsequent development phases.[1]

4.2 Second Milestone

The second milestone focused on building a comprehensive dataset infrastructure through two distinct phases.

Phase 1: Cardano Smart Contract Dataset Compilation

We systematically compiled a dataset of open-source Cardano smart contracts from 40 publicly available repositories, distributed across the three main smart contract languages: 14 Aiken repositories, 21 Plutus repositories, and 5 OpShin repositories. This foundational dataset is hosted on GitHub[2] with automated scripts for pulling data, updating repositories, filtering contracts, and generating basic statistics. The dataset architecture supports easy extensibility, allowing new repositories to be added seamlessly.

[1] https://github.com/unboundedmarket/smart-contract-vulnerabilities/blob/main/reports/1200174_Vulnerability_Scanner.pdf

[2] https://github.com/unboundedmarket/cardano-smart-contracts

Phase 2: Vulnerability Dataset Creation

Building upon the compilation phase, we created a specialized dataset containing smart contracts with systematically introduced vulnerabilities. Using GPT-4o with carefully designed prompts, we generated buggy versions of contracts paired with detailed vulnerability explanations. The complete vulnerability dataset and all processing scripts are publicly available.[3] The repository includes comprehensive scripts for cleaning, preprocessing, augmenting, and postprocessing the data, with extensive documentation in the README facilitating swift onboarding of new developers and contributors.

All data collection processes, preprocessing pipelines, and quality control procedures were thoroughly documented to ensure reproducibility and enable community contributions to the dataset.

4.3 Third Milestone

The third milestone centered on model selection, fine-tuning, evaluation, and comprehensive documentation. We expanded the dataset to 947 high-quality smart contracts[4] through continued data collection and rigorous quality control.

We selected OpenLLaMA-3B (openlm-research/open_llama_3b_v2) as our base model due to its fully open-source nature, public accessibility, and strong performance comparable to other state-of-the-art language models. The model was fine-tuned using instruction tuning to detect vulnerabilities and generate explanations. The fine-tuning process used LoRA (Low-Rank Adaptation) with rank 8 for efficient training, 8-bit quantization to reduce memory requirements, a cosine learning rate scheduler with warmup, and Flash Attention with gradient checkpointing for optimization.

All deliverables were made publicly available: the fine-tuned model was published on HuggingFace[5] for easy community access and integration, all data processing, training, and evaluation scripts were released on GitHub[6] with comprehensive README documentation, and a detailed technical report[7] documenting the model selection process, fine-tuning methodology, hyperparameters, and evaluation results was published.

4.4 Final Milestone

The final milestone focused on community engagement, iterative improvement, comprehensive documentation, and project closeout. Following the public release of the

[3] https://github.com/unboundedmarket/smart-contract-vulnerabilities
[4] https://github.com/unboundedmarket/smart-contract-vulnerabilities/blob/main/data/postprocessed/postprocessed_good.jsonl
[5] https://huggingface.co/unboundedmarket/vulnerabilities-openllama-3b
[6] https://github.com/unboundedmarket/smart-contract-vulnerabilities
[7] https://github.com/unboundedmarket/smart-contract-vulnerabilities/blob/main/reports/1200174_M3_Fine_Tuning_Vulnerability_Scanner.pdf

vulnerability scanner, we engaged with the Cardano community through X (Twitter) announcements and direct feedback collection. Developers who tested the tool provided critical insights on usability barriers, including missing dependency management, hard-coded file paths, and insufficient documentation of project context and research outputs.

The milestone successfully transformed the vulnerability scanner from a technical prototype into an accessible, community-ready tool for enhancing Cardano smart contract security.

4.5 Addressing Community Feedback

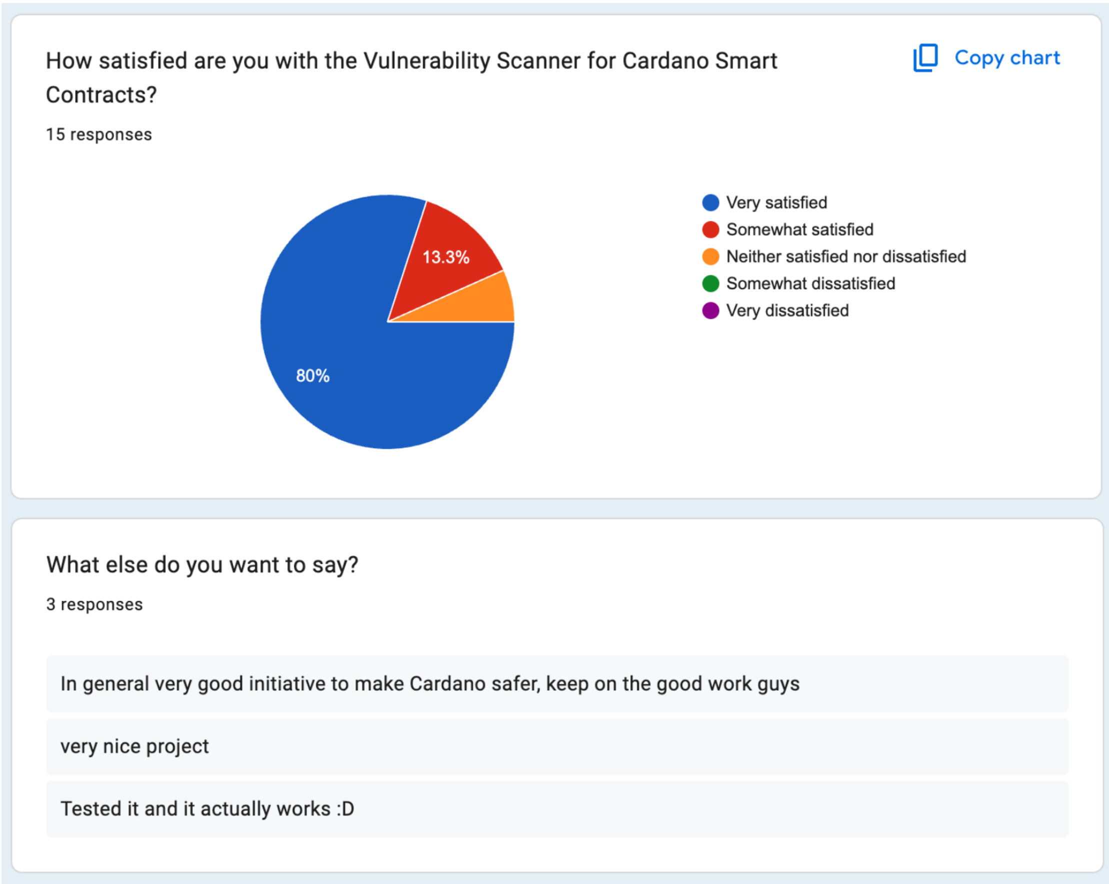
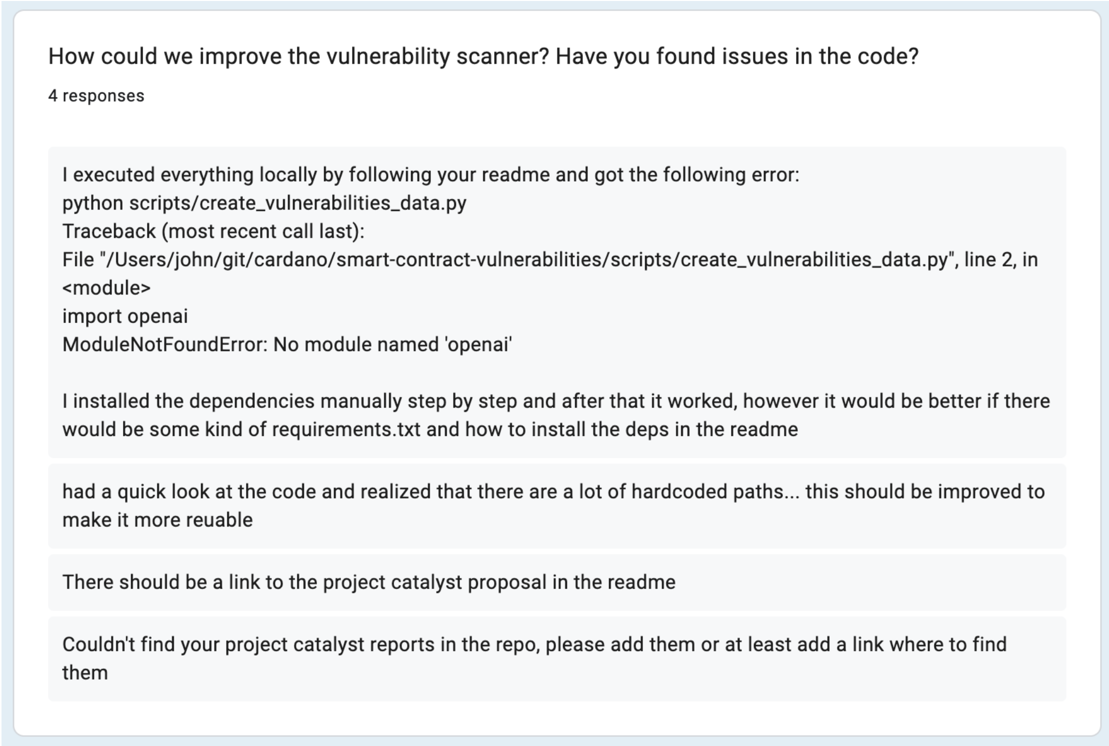


Figure 1: Summary of user satisfaction and general comments.

Following the public release of the vulnerability scanner, we collected structured feedback from the Cardano community via a public form. Overall satisfaction was high, with the majority being *very satified.* The feedback highlighted four primary issues to improve. Users reported immediate failures when running scripts due to missing Python dependencies (`ModuleNotFoundError: No module named 'openai'`), noting the absence of a `requirements.txt` file. Code inspection revealed extensive use of hardcoded file paths throughout the codebase, limiting reusability. Additionally, users could not find references to the Project Catalyst proposal or locate the detailed research reports and milestone deliverables within the repository.



How could we improve the vulnerability scanner? Have you found issues in the code?

4 responses

I executed everything locally by following your readme and got the following error:
python scripts/create_vulnerabilities_data.py
Traceback (most recent call last):
File "/Users/john/git/cardano/smart-contract-vulnerabilities/scripts/create_vulnerabilities_data.py", line 2, in <module>
import openai
ModuleNotFoundError: No module named 'openai'

I installed the dependencies manually step by step and after that it worked, however it would be better if there would be some kind of requirements.txt and how to install the deps in the readme

had a quick look at the code and realized that there are a lot of hardcoded paths... this should be improved to make it more reuable

There should be a link to the project catalyst proposal in the readme

Couldn't find your project catalyst reports in the repo, please add them or at least add a link where to find them

Figure 2: Qualitative feedback highlighting requested improvements to the Vulnerability Scanner.

We addressed all issues directly:

- A comprehensive `requirements.txt` file was added with all necessary dependencies (`openai`, `tiktoken`, `torch`, `transformers`, `accelerate`, `tqdm`), along with detailed installation instructions in the README.[8]
- The `openai` package was updated and the code adapted to it's latest version.[9]
- All scripts were refactored to use Python's `argparse` module, replacing hardcoded paths with configurable command-line arguments (`--input-dir`, `--output-file`,

[8] https://github.com/unboundedmarket/smart-contract-vulnerabilities/commit/4e25aa788e821e82ae2f8ca31076468f53688ee0

[9] https://github.com/unboundedmarket/smart-contract-vulnerabilities/commit/89b9c7c245736893594ea773d86754f98ed012c0

etc.) and sensible defaults.[10]

- The README was updated with prominent Project Catalyst references (project number 1200174) and an acknowledgments section linking to the milestone tracker.[11]
- A dedicated `/reports` directory was created containing all milestone deliverables, with direct links added to the README for easy access.[12]

These changes were implemented immediately after feedback collection and are now part of the main branch, transforming the repository from technically sound but difficult-to-use into a genuinely accessible tool for the Cardano developer community.

5 Links to Relevant Sources

- IdeaScale/Fund page: https://projectcatalyst.io/funds/12/cardano-open-developers/open-source-vulnerability-scanner-for-cardano-smart-contracts
- Main GitHub Repository with Code and Scripts: https://github.com/unboundedmarket/smart-contract-vulnerabilities
- Cardano Smart Contracts Dataset Repository: https://github.com/unboundedmarket/cardano-smart-contracts
- Fine-tuned Model on HuggingFace: https://huggingface.co/unboundedmarket/vulnerabilities-openllama-3b
- Research Report: https://github.com/unboundedmarket/smart-contract-vulnerabilities/blob/main/reports/1200174_Vulnerability_Scanner.pdf
- Community Announcements:
  - https://x.com/unboundedmarket/status/1853793456801366388
  - https://x.com/unboundedmarket/status/1868638578936512917
  - https://x.com/unboundedmarket/status/1872601932818427936
  - https://x.com/unboundedmarket/status/1816780666576511039
  - https://x.com/unboundedmarket/status/2010855904259031443

[10] https://github.com/unboundedmarket/smart-contract-vulnerabilities/commit/c81bcacad057bf4a3a6c681fa4fba5c1ce1a68d6

[11] https://github.com/unboundedmarket/smart-contract-vulnerabilities/commit/9a9de295b07df4013eb5f1459857ae77c68bc8e3

[12] https://github.com/unboundedmarket/smart-contract-vulnerabilities/commit/b14a5350d3e4c3a50614762e12f1dbb7a2f694eb

  - https://x.com/unboundedmarket/status/2012868911012737430

- Feedback Form: https://t.co/Lp3f2YALX2
- Close-out Video Link: https://youtu.be/oBPwNSgYcv8